

Security incident report

Section 1: Identify the network protocol involved in the incident

The primary protocol involved in this incident is **HTTP (Hypertext Transfer Protocol)**.

The attack began when the compromised web server delivered malicious content to users. The tcpdump logs show HTTP requests and responses between the client browser and the web server. Specifically, after the initial DNS resolution, the browser used HTTP to load the website and download the malicious file. The redirection to the fake domain (greatrecipesforme.com) and delivery of the malware were also carried out over HTTP at the application layer.

Section 2: Document the incident

A former employee carried out a **brute force attack** against the administrative account of yummyrecipesforme.com. By guessing the default admin password, the attacker gained access to the web host, modified the site's source code, and injected malicious JavaScript. This script redirected visitors to a fake website and prompted them to download a malware disguised as a recipe update.

Several customers contacted the helpdesk after noticing their computers slowing down and being redirected to suspicious pages. The website owner was locked out of the admin panel.

During the investigation, a sandbox environment was used to safely analyze the website. Tcpdump captured the traffic, revealing:

- DNS resolution for yummyrecipesforme.com
- HTTP requests to load the page
- Redirection to greatrecipesforme.com
- Download of the malicious executable

Source code analysis confirmed the injected JavaScript. The root cause was the use of a weak default admin password and lack of brute force protections.

Section 3: Recommend one remediation for brute force attacks

The team plans to implement the following key measures to prevent similar brute force attacks in the future:

- **Enforce strong password policies** – Require complex passwords, disallow default or common passwords, and mandate regular password updates.

- **Implement Multi-Factor Authentication (MFA / 2FA)** – Require a second form of verification (such as an authenticator app or email/SMS code) for all administrative accounts. This ensures that even if a password is compromised, the attacker cannot gain access without the additional factor.

These controls are highly effective because they address the core weakness exploited in this incident — weak authentication. MFA, in particular, provides strong protection even if passwords are guessed or leaked.